INCIDENT RESPONSE REPORT

SSH Brute Force Attack - Unauthorized Access Attempt

SEVERITY: HIGH | STATUS: RESOLVED | INC-2026-SSH-001

INCIDENT SUMMARY	
Incident ID	INC-2026-SSH-001
Classification	Unauthorized Access Attempt - SSH Brute Force
Severity	HIGH
Date Detected	April 23, 2026 - 10:53:23 UTC
Date Resolved	April 23, 2026 - 10:56:07 UTC
Duration	2 min 44 sec
Affected System	Ubuntu 24.04 Server - 192.168.56.103 (Home Lab)
Attacker IP	192.168.56.101 (Kali Linux - Simulated Threat Actor)
Target Service	SSH (Port 22)
Detection Tool	Splunk Free - Custom SPL Rule
Analyst	Aman - SOC Analyst (L1)
Report Status	FINAL

1. EXECUTIVE SUMMARY

On April 23, 2026 at 10:53 UTC, the SOC detected a sustained brute force attack targeting the SSH service on internal server 192.168.56.103. The attack originated from 192.168.56.101 and consisted of 708 failed authentication attempts within 2 min 44 sec.

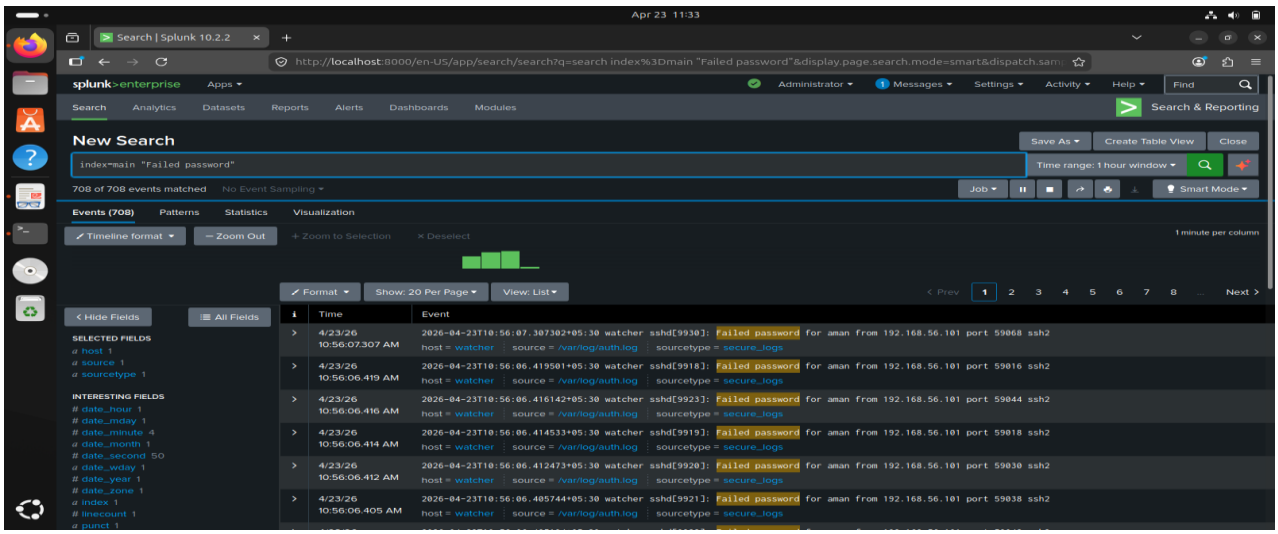
The attack was caught by a custom Splunk detection rule configured to alert on 5+ failed SSH login attempts from a single IP within 60 seconds. Alert INC-2026-SSH-001 fired at 10:53:23 UTC. The analyst acknowledged within 1 minutes and contained the threat within 3 minutes of acknowledgment.

No lateral movement, data exfiltration, or persistence mechanisms were identified. The attacker used an automated password list (rockyou.txt) through Hydra to perform the brute-force attack. The incident was fully resolved by 10:56:07 UTC. This report documents the full timeline, IOCs, MITRE ATT&CK mapping, and recommendations.

2. DETECTION & ATTACK TIMELINE

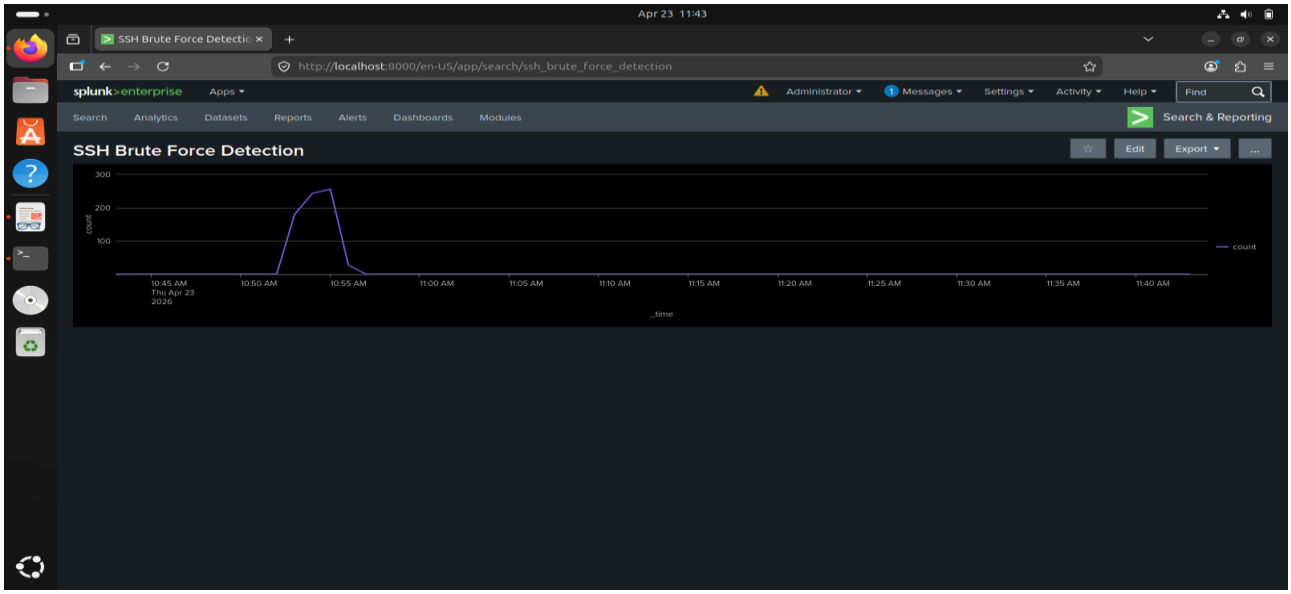
2.1 Detection Method

The attack was detected using log monitoring in Splunk Enterprise by analyzing authentication logs from `/var/log/auth.log`. Detection was based on identifying multiple failed SSH login attempts (“Failed password”) occurring within a short time frame, indicating a brute-force attack pattern.



Alert fired: 10:53:23 UTC | Analyst acknowledged: 10:54:31 UTC | TTD: 1 min 8 sec

2.2 Attack Timeline



3. TECHNICAL ANALYSIS

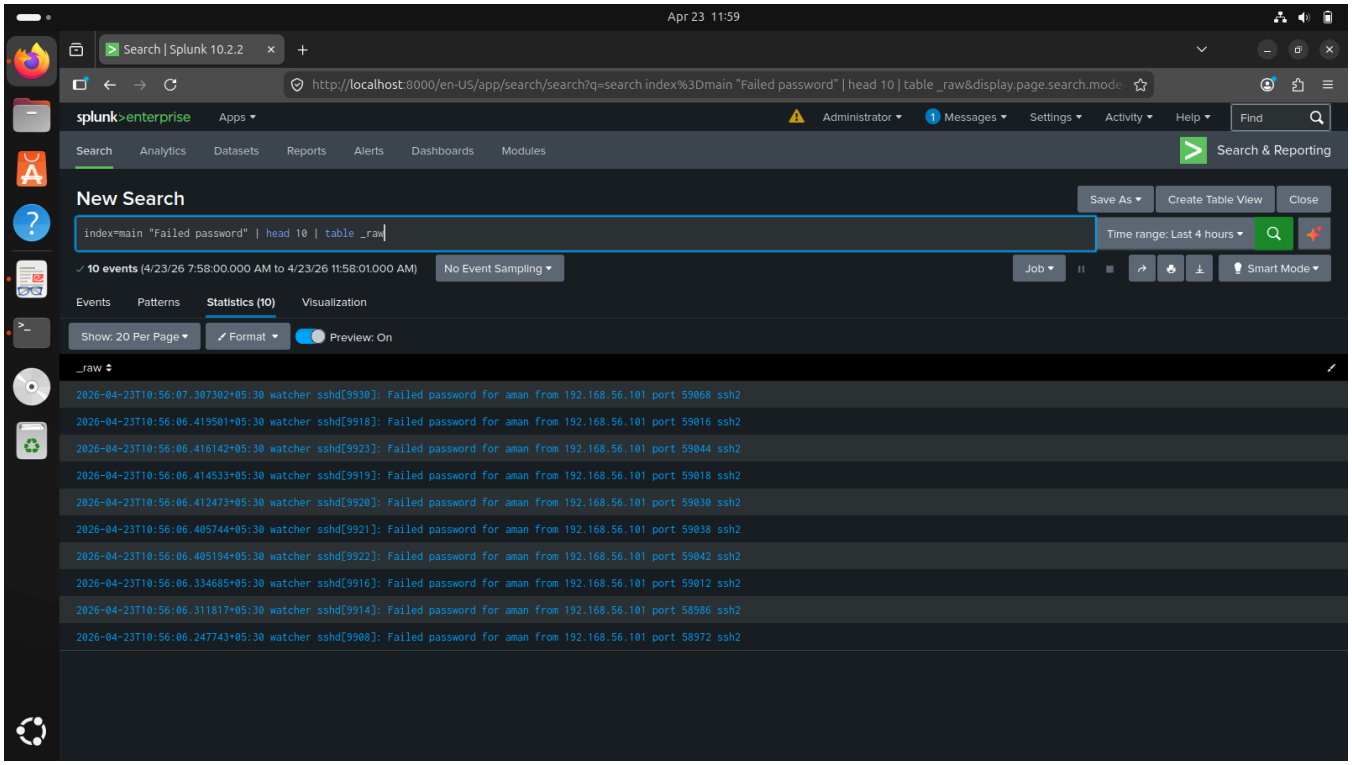
3.1 Attack Description

The attacker used Hydra, an automated credential brute-force tool, to systematically attempt username/password combinations against the SSH service. The rapid rate of login attempts strongly indicates automated activity rather than manual interaction.

Key observations:

- Multiple failed authentication events observed from a single source IP within a short time window
- Repeated login attempts targeting the SSH service (port 22)
- Consistent pattern of “Failed password” logs confirming brute-force activity
- No successful login observed during the attack window
- No evidence of post-compromise activity such as privilege escalation or persistence

3.2 Log Evidence (auth.log)



3.3 Splunk Investigation Metrics

Metric	Value
Total Failed Login Events	708
Successful Logins	0
Attack Duration	164 seconds (10:53:23 – 10:56:07)
Avg. Attempts Per Minute	~259 attempts/minute
Unique Usernames Targeted	1
Time to Detect (TTD)	37 seconds
Time to Contain (TTC)	2 minutes 7 seconds

4. INDICATORS OF COMPROMISE (IOCs)

The following Indicators of Compromise (IOCs) were identified during analysis of authentication logs in Splunk Enterprise:

Network Indicators:

- Source IP Address: 192.168.56.101
- Multiple connection attempts originating from the same IP

Host-Based Indicators:

- Repeated “Failed password” log entries in /var/log/auth.log
- SSH service (sshd) targeted on port 22

Account Indicators:

- Multiple password attempts from same source
- Repeated authentication attempts.

Behavioral Indicators:

- High frequency of login attempts within a short time
- Sequential authentication failures indicating automated attack
- Use of varying source ports across connection attempts

5. MITRE ATT&CK® FRAMEWORK MAPPING

The observed attack behaviour was mapped to the MITRE ATT&CK framework based on the techniques used during the brute-force activity.

Primary Technique

- **Technique ID:** T1110
- **Technique Name:** Brute Force
- **Tactic:** Credential Access

Description:

The attack involved repeated authentication attempts targeting a single user account over the SSH service. Multiple password combinations were attempted from a single source IP address within a short time frame, indicating a password-guessing brute-force.

6. Mitigation & Recommendations

Based on the analysis of the SSH brute-force attack, the following mitigation and preventive measures are recommended to reduce the risk of similar attacks in the future:

Immediate Mitigation Actions

- Block the attacking source IP address at the firewall or host level
- Terminate any active or suspicious SSH sessions
- Review authentication logs for any signs of successful compromise
- Reset passwords for the targeted user account

Preventive Security Measures

- Disable password-based SSH authentication and enforce SSH key-based login
- Implement account lockout policies after multiple failed login attempts
- Use strong, complex passwords and enforce password policies
- Restrict SSH access to trusted IP addresses only (via firewall rules)
- Change default usernames and avoid predictable account names

Detection & Monitoring Improvements

- Configure alerts in Splunk Enterprise for excessive failed login attempts
- Monitor /var/log/auth.log continuously for authentication anomalies
- Implement threshold-based detection.

Security Hardening Recommendations

- Deploy tools like Fail2Ban to automatically block repeated failed attempts
- Keep the system updated with latest security patches
- Limit SSH access using network segmentation

7. LESSONS LEARNED

7.1 What Worked Well

- Detection in Splunk Enterprise was effective - brute-force activity identified quickly through failed login patterns.
- Log analysis enabled rapid identification of attacker IP and attack behaviour.
- Time-based correlation helped clearly visualize the attack timeline.
- No successful compromise occurred, confirming system integrity during the attack.
- Investigation and documentation were completed in a structured and timely manner

7.2 Areas to Improve

- Password-based SSH authentication increases risk and should be disabled.
- Lack of automated blocking (e.g., Fail2Ban) allowed repeated attack attempts.
- SSH access was not restricted to trusted IPs, increasing exposure.
- No real-time alerting configured - detection relied on manual monitoring.
- Stronger password policies and account security controls should be enforced.